

****Supervision of Hillerød Municipality****

****Date:** 22-12-2023**

****Decision****

****Public Authorities****

****Serious Criticism****

****Order****

****Supervision / Self-Management Case****

****Processing Security****

****Fundamental Principles****

****Risk Assessment and Impact Analysis****

The Data Protection Agency has made decisions in five supervisory cases regarding the processing security in AULA. The Data Protection Agency found reason to issue orders for the preparation of impact analyses in two of the cases. In addition, the agency has expressed criticism and serious criticism in the cases.

****Journal Number:** 2023-423-0009.**

****Summary****

The Data Protection Agency initiated supervision in the autumn of 2021 concerning the processing of personal data in the IT system AULA by a total of six selected municipalities. The supervision focused on compliance with the data protection regulation's rules on processing security and impact analysis. "When schools/childcare institutions and parents communicate via AULA, sensitive and confidential information about children is often included. It is therefore important that municipalities take good care of the information in AULA. Children have, according to the data protection regulation, a right to special protection," says Signe Vestergård, special consultant at the Data Protection Agency.

The Data Protection Agency has now made decisions in all cases except one, as this case contains some additional elements.

The supervision is a continuation of the Data Protection Agency's previous supervision of Kombit A/S (hereinafter KOMBIT) in December 2019. During that supervision visit, the Data Protection Agency found that KOMBIT could not be regarded as the data controller for AULA under Article 4, No. 7 of the data protection regulation. At the supervisory meeting, the Data Protection Agency informed KOMBIT that KOMBIT should ensure that all municipalities were informed of their data responsibility and that KOMBIT should transfer all necessary materials and information to the municipalities in this regard.

The Data Protection Agency finds that the supervisory cases raise some general data protection legal issues across the municipalities, which can be better handled collectively rather than separately at the individual municipalities. Therefore, the Data Protection Agency has chosen to inform the Danish Municipalities Association (KL), the Agency for IT and Learning, and Kombit A/S (hereinafter KOMBIT) about the agency's decisions in these cases. At the same time, the Data Protection Agency has formulated some recommendations for further work on processing security in AULA.

Furthermore, the Data Protection Agency will provide the same recommendations in a letter to all municipalities in the country, where the agency will also inform about the decisions. The purpose of the information to the municipalities is to encourage them to consider whether the material gives rise to (further) assessments, etc., or to ensure the implementation of additional security measures concerning their processing of personal data in AULA.

****Impact Analysis****

Although the five municipalities use the same technical solution (AULA) for the same processing activities, they have had a markedly different approach to the issue of impact analyses. All five municipalities have received criticism or serious criticism in the part of the cases concerning impact analysis. Two of the municipalities have received serious criticism for not having prepared an impact analysis. The Data Protection Agency has furthermore issued these two municipalities an order to prepare an impact analysis within three months.

The other three municipalities have prepared impact analyses. The Data Protection Agency has reviewed them and assessed that none of them meet all the minimum requirements for an impact analysis.

In addition, the Data Protection Agency has examined the timing of the preparation of the impact analyses and taken into account that there has been uncertainty regarding the data responsibility for the processing of personal data in AULA. The municipalities and KOMBIT have thus been of the opinion that the data responsibility for the processing of personal data and the responsibility for conducting risk assessments and impact analyses lay with KOMBIT. However, the Data Protection Agency concluded during the supervisory visit to KOMBIT in December 2019 that KOMBIT cannot be considered as the data controller.

All three municipalities prepared the impact analyses only long after clarity regarding the data responsibility for the processing of personal data in AULA had been established. Two of the municipalities even prepared the impact analyses only after the agency requested the material in connection with the initiation of the supervision, which is why the Data Protection Agency has expressed serious criticism towards these two municipalities. The Data Protection Agency has expressed criticism towards the third municipality.

****Risk Assessment****

All five municipalities have also received criticism or serious criticism regarding the part of the cases that concern the municipalities' risk assessments. The criticism relates to the documentation requirement to demonstrate that they have identified and mitigated the risks that the processing of personal data in AULA poses for the individuals concerned, ensuring an appropriate level of security. In addition, the criticism concerns the lack of identification and implementation of relevant measures to ensure an appropriate level of security.

The Data Protection Agency has expressed serious criticism of two of the municipalities for not having submitted actual risk assessments. One municipality stated in January 2023 that they had not yet completed the initial work of identifying relevant measures that can be implemented with a view to... to reduce the identified high risks associated with the processing of personal data in AULA. The second municipality referred to a number of appendices as documentation for the mitigating measures the municipality had taken to reduce the risk for the registered individuals. The other three municipalities have submitted risk assessments. However, the Data Protection Agency has expressed criticism towards these municipalities, as they have not sufficiently demonstrated that they have ensured an appropriate level of security.

Several municipalities have submitted material from KOMBIT, where a number of high risks associated with the use of AULA have been identified. The municipalities have responded differently to the material. Some municipalities have stated that they have adopted KOMBIT's risk assessment and have based their descriptions of the measures they have implemented to reduce these risks on it. One municipality indicates that they have reviewed the material from KOMBIT but concluded that it could not be immediately used as a basis for actual risk assessments. Other municipalities have conducted their own assessments, where some of the risks they have identified are assessed to pose a lower risk than what is indicated in KOMBIT's material—though without sufficiently documenting the basis for this assessment.

****Risk of Misdelivery in AULA****

The Data Protection Agency has found that a large portion of the reports of breaches of personal data security in AULA that the agency receives concern the misdelivery of personal data to one or more incorrect recipients in AULA. This is also a risk that several municipalities have identified in their risk assessments. Several of the municipalities have implemented organizational measures to inform users about this risk when sending messages via AULA. Additionally, one of the municipalities has also had a change request implemented in AULA that allows for the deletion and editing of sent content in messages.

Despite these measures, the Data Protection Agency continues to receive a number of reports of breaches from municipalities concerning misdelivery in AULA. It is generally the Data Protection Agency's view that data controllers who systematically use a technical functionality to send messages containing confidential and/or sensitive information should investigate whether it is possible to implement one or more technical measures to reduce the risk of misdelivery. They should also explore

the possibilities of designing the messaging function in a way that minimizes such risks.

In a letter to KL, KOMBIT, and the Agency for IT and Learning, the Data Protection Agency has recommended that KOMBIT, together with the data-controlling municipalities, conduct such an investigation. This recommendation will also be reiterated in a letter to all municipalities in the country.

****Joint Impact Assessment and Code of Conduct****

It is the Data Protection Agency's view that municipalities have the opportunity to prepare a joint impact assessment regarding data protection for their processing of personal data in AULA. This is based on the fact that the municipalities use the same type of system for the same processing activities of the same type of personal data, and that the municipalities' processing activities involve similar high risks. Furthermore, the system is provided by the same supplier.

In the letter to KL, KOMBIT, and the Agency for IT and Learning, the Data Protection Agency has therefore urged that it be considered across municipalities, and possibly in collaboration with KL and KOMBIT, to prepare a joint impact assessment regarding the municipalities' processing of personal data in AULA.

The Data Protection Agency has additionally recommended that KL, in collaboration with the municipalities and possibly KOMBIT, consider the possibility of developing a code of conduct in accordance with Article 40 of the General Data Protection Regulation regarding the municipalities' processing of personal data in AULA. The Data Protection Agency has noted that this consideration may also be relevant for other processing activities in the municipalities, where they use the same system for the same processing activities of the same types of personal data, which involve similar high risks.

A code of conduct can provide correct and practical guidance on how to organize oneself in connection with one or more processing activities to comply with data protection rules. This could, for example, involve establishing procedures that must be followed for a specific processing activity. A code of conduct would therefore be a useful tool to help comply with data protection rules for the authorities that have subscribed to the code. Although it facilitates compliance with the rules, it does not exempt the individual data controller from the obligations and tasks that fall on them as data controllers. This is particularly significant in situations where the data controller chooses to deviate from the assumptions in the joint concepts and processing—e.g., by using a system for other purposes.

"It is a large and resource-intensive task for individual municipalities to conduct risk assessments and impact assessments that ensure the appropriate security measures. But it is necessary. AULA is a tool used in all municipalities for the same processing activities of the same type of personal data. We therefore encourage the municipalities—possibly in collaboration with KL and KOMBIT—to come together and ensure that citizens' information in AULA is adequately protected," says Signe Vestergård, special consultant at the Data Protection Agency.

1. **Written Supervision of Hillerød Municipality Regarding the IT System AULA**

Hillerød Municipality is among the six municipalities that...

****Datatilsynet**** in the autumn of 2021 selected to conduct supervision in accordance with the General Data Protection Regulation[1] and the Data Protection Act[2].

Datatilsynet's supervision is a written oversight with a particular focus on the technical and organizational security measures that have been observed to comply with the requirement for an appropriate level of security for the processing activities in the IT system AULA.

The supervision is a continuation of Datatilsynet's previous oversight of Kombit A/S (hereinafter referred to as KOMBIT) in December 2019, where the supervision during a site visit could ascertain that KOMBIT is not to be regarded as the data controller for AULA under Article 4, No. 7 of the General Data Protection Regulation. Therefore, Datatilsynet informed KOMBIT that KOMBIT must ensure that all municipalities are informed of their data responsibilities and that KOMBIT transfers all necessary materials and information to the municipalities in this regard.

Datatilsynet expects that KOMBIT has informed the municipalities about this immediately after the site visit in December 2019.

****2. Decision****

After a comprehensive assessment of Hillerød Municipality's statements and the submitted materials, Datatilsynet finds that Hillerød Municipality has not demonstrated that the municipality has identified the risks that the municipality's processing of personal data in AULA poses to the data subjects, nor does the supervision find it demonstrated that the municipality has implemented appropriate security measures that protect the data subjects against these risks.

On this basis, Datatilsynet finds grounds to express serious criticism that Hillerød Municipality's processing of personal data has not been conducted in accordance with Article 5, paragraph 2, in conjunction with paragraph 1, letter f, and Article 24, paragraph 1, in conjunction with Article 32, paragraph 1 of the General Data Protection Regulation.

Datatilsynet further finds grounds to express serious criticism that Hillerød Municipality's processing of personal data has not been conducted in accordance with Article 35, paragraph 1, first sentence, of the General Data Protection Regulation, as Hillerød Municipality has not prepared a data protection impact assessment for the processing of personal data in AULA. Hillerød Municipality has stated that they have not identified specific needs to conduct a data protection impact assessment.

On this basis, Datatilsynet finds grounds to issue Hillerød Municipality an order to conduct a data protection impact assessment regarding the municipality's processing of personal data in AULA in accordance with Article 35 of the General Data Protection Regulation. The order is issued pursuant to Article 58, paragraph 2, letter d of the General Data Protection Regulation.

The deadline for compliance with the order is March 22, 2024. Datatilsynet requests to receive confirmation by the same date that the order has been complied with. According to Section 41, paragraph 2, No. 5 of the Data Protection Act, it is punishable to fail to comply with an order issued by Datatilsynet pursuant to Article 58, paragraph 2 of the General Data Protection Regulation. According to Section 41, paragraph 6, second sentence of the Act, public authorities may also be penalized.

Datatilsynet notes that it follows from Article 36, paragraph 1 of the General Data Protection Regulation that if the data protection impact assessment shows that the processing will lead to high risk in the absence of measures taken by Hillerød Municipality to mitigate the risk, Hillerød Municipality must consult Datatilsynet.

Hillerød Municipality must therefore consult Datatilsynet if Hillerød Municipality, in connection with the preparation of the data protection impact assessment, assesses that they cannot adequately mitigate the identified risks, as the residual risks remain high.

****3. Case Presentation****

Datatilsynet has, by letter dated October 15, 2021, notified the supervision of Hillerød Municipality. In this connection, Datatilsynet has requested the municipality to submit the following:

1. The risk assessments that form the basis for the assessment of what security is deemed appropriate for the processing of personal data in "AULA," as well as a description of the general security models in the application.
2. To the extent that data protection impact assessments have been prepared, copies of all versions of these.
3. A review of considerations regarding the use of Article 25 of the General Data Protection Regulation in connection with the procurement and development of "AULA."
4. A review of authorization and access control models.

Hillerød Municipality submitted a statement regarding the case along with a number of appendices on November 5, 2021. Additionally, Hillerød Municipality submitted further appendices on July 1, 2022, which Datatilsynet was unable to open during the initial submission.

Based on the statements from the six selected municipalities, Datatilsynet has chosen to narrow the focus of the supervision to questions regarding risk assessment and data protection impact assessment. It should be emphasized in this context that Datatilsynet has not, in connection with this supervision, taken a position on whether Hillerød Municipality's processing of personal data in AULA is in accordance with Article 25 of the General Data Protection Regulation regarding data protection by design and by default, or whether the municipality's authorization and access control models are in

accordance with Article 32 of the General Data Protection Regulation.

Datatilsynet has subsequently, by letters dated December 6, 2022, and February 8, 2023, posed a number of clarifying questions to Hillerød Municipality regarding the municipality's responses concerning risk assessments. The municipality has answered these questions on January 5 and 9, 2023, as well as March 3, 2023.

****3.1. General Information on the Decision and Development of AULA****

The Danish Municipalities' Association (hereinafter KL) informs that their website, that the municipal procurement of AULA is part of the User Portal Initiative, which is a political initiative from 2013.[3] It further states that AULA aims to support communication and thus collaboration regarding children's learning and well-being in a secure and user-friendly manner. KL also informs that all 98 municipalities in Denmark in 2016 came together for a joint procurement of a collaboration platform – the later AULA – for the school sector. Furthermore, it appears from KL's website that AULA was put out to tender by the municipalities' IT community, KOMBIT A/S (hereinafter KOMBIT), at the beginning of 2017, and the choice fell on the supplier Netcompany – IT and Business Consulting, which has since developed AULA in collaboration with the companies Frog, EduLab, and Advice. KOMBIT provides information about AULA on the website aulainfo.dk. It is stated there that the majority of public schools started using AULA in 2019 and daycare institutions in the winter of 2020/2021.[4] The Data Protection Agency has understood that the individual municipalities are independently data controllers for their processing of personal data in AULA, and that KOMBIT, which is the municipalities' data processor, has entered into a data processing agreement with Netcompany, which is thus a sub-processor.[5]

3.2. Hillerød Municipality's Comments

3.2.1. Risk Assessment

Hillerød Municipality has stated that after being awarded the tender, Netcompany initiated the development of AULA based on, among other things, requirement specifications that were jointly provided during the tender negotiations. Hillerød Municipality has submitted a number of risk assessments and stated that work was conducted based on these assessments. Furthermore, Hillerød Municipality has informed that the municipality's public schools began using AULA in the autumn of 2019, and during 2020, AULA was also adopted in the municipality's daycare institutions. Hillerød Municipality has in this connection stated that security work continued thereafter and is ongoing to this day. Hillerød Municipality has submitted 37 appendices with material that was prepared as part of the formulation of the tender material and which has been continuously supplemented as AULA has been further developed. The material contains the risk assessments that underlie what security is generally considered appropriate for the processing of personal data in AULA, as well as descriptions of the general security models that were prepared as part of the formulation of the tender material. It appears from a cover letter to the risk assessments and security models that KOMBIT has prepared a risk assessment of AULA in relation to data protection legislation, which aims to have a risk-based approach to the protection of personal data. It further states that KOMBIT has shared this with the municipalities so that it can serve as input for the municipalities' work on risk assessment in the school and daycare sectors. Finally, it appears that a general risk assessment has been made, consisting of five documents that are divided according to data processes for AULA, as well as specific IT risk assessments for 11 selected modules in AULA as a supplement to the general risk assessment. The Data Protection Agency has understood from KOMBIT's material that it is their assessment that the processing of personal data in AULA generally involves several high risks. For example, it appears in KOMBIT's risk assessment for the messaging module in AULA that they have identified 10 threats, three of which are deemed most likely. The three threats are marked as red, and the Data Protection Agency understands from the material that KOMBIT has assessed that these represent high risks. One of the threats concerns user behavior that leads to mishandling of personal data in the system, carried out by an authorized user through unintentional disclosure of personal data in the application. The consequence is categorized as "devastating," and it is stated, among other things, that children may suffer significant harm to their reputation, which can lead to social losses. The likelihood is categorized as "expected," and it is stated, among other things, in this context that it is expected that there will be

cases where a user mistakenly sends a message containing personal data to one or more users, for example, by sending to a group. Hillerød Municipality draws the Agency's attention in their statement that these appendices are only KOMBIT's overarching risk assessments, and that Hillerød Municipality has discussed the identified risks and worked with these based on local conditions. In this connection, Hillerød Municipality states that KOMBIT's general assessment that, for example, it is expected that an incident will occur, is not indicative of the final risk assessment that has been discussed locally at Hillerød Municipality. The Data Protection Agency has therefore requested Hillerød Municipality to submit dated copies of the municipality's work on this, as the municipality does not appear to have submitted the assessments that the municipality has specifically made. The Data Protection Agency has also asked Hillerød Municipality to inform what these local assessments have specifically led the municipality to. In this connection, the Data Protection Agency has asked Hillerød Municipality to inform whether they have taken mitigating measures based on their local assessments with the aim of reducing the risk to the registered individuals, and if so, what mitigating measures the municipality has taken. If Hillerød Municipality has not taken mitigating measures, the Data Protection Agency has asked Hillerød Municipality to inform the Agency of the reasons for this. Hillerød Municipality has, in their response to the Data Protection Agency, referred to the appendices that Hillerød Municipality submitted in connection with their original response. In this connection, Hillerød Municipality, specifically referred to the municipality's description of login methods in AULA, descriptions of roles and rights in AULA, as well as a strategy for the use of AULA in Hillerød Municipality. Hillerød Municipality has also attached 105 appendices to their response and stated that this is part of the municipality's response to the supervision. The appendices include, among other things, letters to employees and parents regarding the postponement of AULA, widget guides, guidance on logging in with SoloID, various email correspondences regarding, for example, the creation of externals in AULA, as well as forms in AULA.

The Data Protection Agency has subsequently requested the municipality to address the following high risks associated with the municipality's use of AULA, as identified in the previously submitted material by KOMBIT:

1. Lack of access control or errors in this
2. Mismanagement of personal data in the system/solution, carried out by an authorized user
3. Incorrect handling due to incorrect or missing implementation of data classification in the solution
4. Incorrect accesses due to missing or unclear policies
5. Use of inadequately protected username and password

In this context, the Data Protection Agency has requested Hillerød Municipality to inform whether the municipality has taken – and if so, which – mitigating measures to reduce these high risks, or what the reason is for the municipality not having taken mitigating measures, if that is the case.

Hillerød Municipality has stated in its response to the Data Protection Agency that KOMBIT's material is merely an expression of a supplier's viewpoint, and that the municipality is in no way obligated to address or otherwise take the material into account. In this connection, Hillerød Municipality has stated that the municipality has reviewed the material but concluded that its nature was and is of such poor quality that it could not immediately be used as a basis for actual risk assessments. Hillerød Municipality has therefore discussed the material locally and reassessed it based on local conditions.

Hillerød Municipality has noted that caution should generally be exercised when using risk material from suppliers, as they often have weighted interests such as desires for upselling, which is why suppliers often have "solutions" to the "problems" they themselves have identified.

Hillerød Municipality has subsequently referred to the previously submitted appendices as dated documentation for which mitigating measures Hillerød Municipality has taken to reduce the risk to the registered individuals as part of the implementation and use of AULA. Hillerød Municipality has stated that the mitigating measures are both technical and organizational in nature and relate, among other things, to training, education, and awareness initiatives for Hillerød Municipality's registered individuals, including, for example, super users, employees, and citizens. The more technical mitigating measures concern the organization and creation of user groups, implementation of user

rights management, multi-factor authentication, backup, and logging. Hillerød Municipality has, as a supplement to the previously submitted appendices, attached another appendix titled "Training Program for Administrative Super Users."

Hillerød Municipality has noted that they lack the Data Protection Agency's legal explanation for which provisions in the General Data Protection Regulation underlie an obligation to have dated copies of the work on identified risks.

Regarding the material from KOMBIT, where the 5 aforementioned risks are identified, Hillerød Municipality has stated that Hillerød Municipality has not identified these risks in collaboration with KOMBIT. Furthermore, Hillerød Municipality has stated that these are not risks but rather vulnerabilities and threats, as defined in ISO 27000 section 2.89, point 2.83, and exemplified in ISO 27005 Annex C and Annex D. Hillerød Municipality has noted that there is only a risk when a relevant vulnerability is linked to a relevant threat.

Hillerød Municipality has further stated that the municipality does not acknowledge in any way that the points are expressions of "high risks." Hillerød Municipality has then provided comments on the 5 aforementioned risks that appear in KOMBIT's material. Hillerød Municipality notes in this context that it is merely an expression of a theoretical exercise carried out by Hillerød Municipality at the request of the Data Protection Agency.

3.2.2. Consequence Analysis

In response to the Data Protection Agency's question regarding the consequence analysis concerning data protection, Hillerød Municipality has stated that neither in connection with the creation of the tender material, the specific implementation, nor based on the latest risk assessments were specific needs identified for conducting consequence analyses, cf. Article 35 of the General Data Protection Regulation.

3.3. Reported Breaches of Personal Data Security Regarding AULA

The background for the Data Protection Agency originally finding it relevant to supervise the municipalities with a particular focus on the technical and organizational security measures observed to meet the requirement for an appropriate level of security for the processing in AULA is that the supervision has seen (and continues to see) a number of reported breaches of personal data security in connection with the processing of personal data in AULA.

In AULA, personal data is processed, including confidential and sensitive personal data, about vulnerable registered individuals, which includes children. Furthermore, the system's users are often individuals who do not as their

****Primary Activities Related to Data Protection****

(including educators, pedagogical staff, as well as students and parents), which, in the opinion of the supervisory authority – in light of the many reported breaches from the vast majority of the country's municipalities – may imply that stricter requirements should be imposed on the data controllers' observance of both technical and organizational measures, cf. Article 32, as well as mitigating measures for compliance with the regulation's Article 25.

A large portion of these reports of breaches of personal data security in AULA concern that personal data has been sent to one or more incorrect recipients in AULA. For example, where a message or secure file about a child has been sent to another child's parents, or where a message has mistakenly been sent to a group of recipients instead of a specific recipient. The Data Protection Authority has also seen cases where, when sending documents to one or more parents, an incorrect document containing information about another child has been attached. Thus, there have been several unintended disclosures of personal data about children in AULA, including descriptions of children's concentration difficulties, settings for pedagogical-psychological assessments, information about dyslexia, school statements, as well as action plans and assessments regarding educational readiness.

Through a search in the Data Protection Authority's ESDH system, the authority can ascertain that it

has received 18 reports of breaches of personal data security from Hillerød Municipality under the data protection regulation's Article 33, where AULA is mentioned in the report. Several of the reports concern unintended disclosures of personal data in the system, where personal data has been sent to one or more incorrect recipients in AULA. There are both cases where a message containing confidential information about a student has been sent to another student's parents, and where a message has been sent to an entire parent group instead of the relevant student's parents. There are also cases where files containing personal data about students have mistakenly been attached to posts on AULA.

Furthermore, several of the reports concern unauthorized access to personal data in AULA, including information about whether a contact person has parental authority over a child and profile pictures that have not had the necessary consent to be displayed.

****4. Justification for the Data Protection Authority's Decision****

****4.1. Risk Assessment****

The Data Protection Authority, based on Hillerød Municipality's own information in the case, assumes that the municipality has consulted KOMBIT's risk assessments, but that the municipality has not endorsed these as being representative of the municipality's risk considerations. The Data Protection Authority further assumes that Hillerød Municipality has discussed the material from KOMBIT locally and reassessed it based on the circumstances applicable to Hillerød Municipality as a data controller. Hillerød Municipality has submitted a number of appendices as documentation for what mitigating measures the municipality has taken to reduce the risk to the data subjects. The Data Protection Authority assumes that there is no additional documentation beyond what has been submitted in the case.

The data protection regulation requires, on several points, that a data controller addresses the risk to the rights and freedoms of the data subjects and can document the considerations and conclusions this has led to. It follows directly from the provisions in Articles 5, paragraph 1, letter f, 24, 25, 32, 33, 34, 35, 36, and 39, that the data controller must address the risk to the rights and freedoms of the data subjects. Furthermore, it follows from both Article 5, paragraph 2, regarding the principles in Article 5, paragraph 1, and Article 24 regarding compliance with the entire regulation, that a data controller must be able to demonstrate compliance with data protection rules. Among other things, Articles 25, 35, and 36 require that considerations regarding the involved risks to the rights of the data subjects must take place before the processing is initiated.

It follows from the data protection regulation's Article 5, paragraph 1, letter f, that personal data must be processed in a manner that ensures adequate security for the relevant personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures. The data controller must also be able to demonstrate that the fundamental principles are adhered to, which follows from the data protection regulation's Article 5, paragraph 2.

According to the data protection regulation's Article 32, paragraph 1, it is stated that the data controller must take appropriate technical and organizational measures to ensure a security level that is appropriate to the risks associated with the data controller's processing of personal data. It follows from the data protection regulation's Article 24, paragraph 1, that a data controller must implement appropriate technical and organizational measures to ensure and to be able to demonstrate that the processing is in accordance with the regulation. The data controller has an obligation to identify the risks that the data controller's processing poses to the data subjects and to ensure that appropriate security measures are implemented to protect the data subjects from these risks. The data controller must also be able to demonstrate that personal data is processed in a manner that ensures adequate security for the individuals to whom the data relates. For the supervisory authority to assess whether an appropriate level of security has been ensured, it must therefore be documented and explained what risks the data controller has identified and what mitigating measures have been taken to reduce these risks.

If a supplier, data processor, or available analyses, etc., establishes or indicates... certain risk scenarios, it is the Data Protection Authority's view that data controllers should address these assessments. Particularly when processing activities in a system are deemed to involve high risks for the data subjects. At a minimum, there must be a substantiated assessment of why the situation is not relevant in the processing of personal data that occurs with the data controller.

It is not explicitly stated anywhere in the General Data Protection Regulation how the documentation should appear, what the specific content should be, or what the frequency of updates and revisions should be. The Data Protection Authority's view is that the documentation obligation implies that the supervisory authority – from the total material that the data controller can present – can assess whether the processing is in accordance with the General Data Protection Regulation. It should thus be evident from the submitted material how and on what basis the data protection considerations have been made. This includes, among other things, the legality of the processing and the ability to ensure compliance with the rights of the data subjects, adherence to the data protection principles, and ensuring an appropriate level of security.

Furthermore, it should be clear what considerations, choices, and omissions have been made to ensure that the processing of the information is in accordance with the General Data Protection Regulation. In this context, it should be possible to timestamp when and with what content relevant considerations and actions have taken place.

After a comprehensive review of all the material from Hillerød Municipality, the Data Protection Authority concludes that no assessment has been presented regarding whether Hillerød Municipality has implemented appropriate technical and organizational measures to ensure a level of security that is commensurate with the risks associated with the processing of personal data in AULA in accordance with Article 32, paragraph 1.

The Data Protection Authority further concludes – after an overall assessment of the submitted material – that Hillerød Municipality has not explained why the risk scenarios indicated by KOMBIT do not occur in the municipality's processing of personal data in AULA, where they deviate from KOMBIT's risk assessment. On this basis, the Data Protection Authority finds that Hillerød Municipality has not demonstrated that the municipality has identified the risks that the municipality's processing of personal data in AULA poses to the data subjects, nor does the authority find it demonstrated that the municipality has implemented appropriate security measures that protect the data subjects against these risks.

The Data Protection Authority therefore expresses serious criticism that Hillerød Municipality's processing of personal data has not been carried out in accordance with the General Data Protection Regulation's Article 5, paragraph 2, in conjunction with paragraph 1, letter f, and Article 24, paragraph 1, in conjunction with Article 32, paragraph 1.

4.2. Consequence Analysis

4.2.1. Requirement for Consequence Analysis

The Data Protection Authority assumes that Hillerød Municipality has not prepared a consequence analysis pursuant to the General Data Protection Regulation's Article 35, paragraph 1, as Hillerød Municipality has stated that they have not identified specific needs to conduct a consequence analysis.

It follows from the General Data Protection Regulation's Article 35, paragraph 1, first sentence, that if a type of processing, particularly using new technologies and by its nature, scope, context, and purpose, is likely to result in a high risk to the rights and freedoms of natural persons, the data controller shall carry out an analysis of the intended processing activities' consequences for the protection of personal data.

In the Article 29 Working Party's (now the European Data Protection Board, EDPB) guidelines on consequence analysis regarding data protection, criteria have been established that can help identify the processing activities that will require a consequence analysis. According to the guidelines, a data controller can generally assume that processing that meets two of the criteria must be subject to a

consequence analysis regarding data protection.

The processing of personal data in AULA meets two of these criteria, as sensitive and confidential personal data about vulnerable data subjects, including children, is processed. Furthermore, it is a system used for collaboration and communication between schools/daycare institutions and children and their parents. In the system, personal data is exchanged in messages, among other things, and there are many users associated with the system. The Data Protection Authority believes that this communication entails a risk that, due to human error, personal data may be inadvertently disclosed to incorrect users. This is particularly relevant considering that the users consist of both municipal employees as well as children and their parents, and that, regardless of guidance, human errors will occur for which there are no immediate mitigating measures.

Generally, based on the types of information processed in AULA, the volume of information, the number of transactions (exchange of information in connection with communication), and the diversity of users, there is not only a potential risk that the risk scenario will occur but also a real one.

The consequences for a data subject's rights can, in the Data Protection Authority's view, range across the entire spectrum of severity of consequences, from less intrusive ones such as receiving unintended messages and similar to more serious ones such as significant reputational damage to, in the most extreme consequence, where a data subject's life is endangered by the disclosure of a concealed address, for just...

to mention some possible consequences. The Data Protection Agency notes that any risk that involves a high consequence for the rights and freedoms of the data subjects – even with relatively low probabilities of the risk materializing – will likely entail a high risk for the rights of the data subjects, which triggers the obligation to conduct a data protection impact assessment, cf. Article 35, paragraph 1 of the regulation.

Furthermore, based on reports of personal data security breaches concerning AULA, the Data Protection Agency has generally found that several of these would likely involve a high risk to the rights and freedoms of individuals. In addition, the Agency has noted in several cases that municipalities have considered the conditions in Article 34 to be met and have notified the data subjects about breaches of personal data security in AULA. The municipalities in question have thus assessed that the breaches likely pose a high risk to the rights and freedoms of individuals.

Based on the above, it is the Data Protection Agency's opinion that the processing of personal data in AULA is likely to entail a high risk to the rights and freedoms of individuals. The Data Protection Agency therefore finds that a data protection impact assessment should have been conducted.

4.2.2. Timing of the Preparation of the Impact Assessment

It follows from Article 35, paragraph 1 of the General Data Protection Regulation that a data protection impact assessment must be conducted prior to the processing.

In connection with a supervisory visit to KOMBIT in December 2019, the Data Protection Agency found that there had been uncertainty regarding where the data responsibility for the processing of personal data in the solution is placed in connection with the development of AULA. Both the municipalities and KOMBIT have thus been of the opinion that the data responsibility for the processing of personal data in AULA – and thus also the responsibility for conducting risk assessments and impact assessments – was placed with KOMBIT.

As stated above under point 1, the Data Protection Agency found during the supervisory visit to KOMBIT that KOMBIT is not to be considered as the data controller, and therefore the Agency informed KOMBIT that it must ensure that all municipalities are informed of their data responsibility, and that KOMBIT must transfer all necessary materials and information to the municipalities in this regard.

Based on the Data Protection Agency's supervisory visit to KOMBIT in December 2019 and the material submitted by KOMBIT in this connection, the Data Protection Agency assumes that KOMBIT, in connection with the development of AULA – and before it was established that the municipalities

were the data controllers – conducted assessments of the risks and consequences for the data subjects related to the processing of personal data in AULA, which show that the processing entails a high risk for the data subjects.

It is thus the Data Protection Agency's opinion that Hillerød Municipality – like the other municipalities – should have recognized the high risk associated with the processing of personal data in AULA in connection with KOMBIT informing the municipalities of their data responsibility regarding the processing of personal data in AULA and transferring all necessary materials in this regard.

It is the Data Protection Agency's expectation that KOMBIT informed the municipalities of this immediately after the supervisory visit in December 2019.

It is the Data Protection Agency's opinion that Hillerød Municipality should have commenced the preparation of a data protection impact assessment at that time.

The Data Protection Agency has particularly taken into account in its assessment that the purpose of a data protection impact assessment is to identify the specific risks posed by the processing to the rights and freedoms of the data subjects and subsequently ensure that measures are established to mitigate these risks and reduce the risk to a level that is less than high before the processing begins.

4.2.3. Overall Assessment Regarding the Impact Assessment

After reviewing the submitted material and Hillerød Municipality's statements, the Data Protection Agency finds that Hillerød Municipality has acted in violation of Article 35, paragraph 1 of the General Data Protection Regulation, as Hillerød Municipality has not prepared a data protection impact assessment for the processing of personal data in AULA. Hillerød Municipality has stated that they have not identified specific needs to conduct a data protection impact assessment.

The Data Protection Agency therefore finds grounds to express serious criticism of Hillerød Municipality's processing of personal data not being in accordance with Article 35, paragraph 1 of the regulation.

On this basis, the Data Protection Agency finds grounds to issue Hillerød Municipality an order to conduct a data protection impact assessment for the municipality's processing of personal data in AULA in accordance with Article 35 of the General Data Protection Regulation. The order is issued pursuant to Article 58, paragraph 2, letter d of the General Data Protection Regulation.

The deadline for compliance with the order is March 22, 2024.

In choosing the reaction, the Data Protection Agency has emphasized that Hillerød Municipality has not prepared a data protection impact assessment for the processing of personal data in AULA despite the fact that the processing of personal data in AULA is likely to entail a high risk to the rights and freedoms of individuals. In this connection, the Data Protection Agency has emphasized that the municipality was made aware shortly after the Data Protection Agency's supervisory visit to KOMBIT in December 2019 that the municipality is

****Data Controller for the Processing of Personal Data in a Solution that Involves a High Risk for the Data Subjects.****

****4.3. Summary****

On the basis of the above, the Data Protection Agency finds grounds to express serious criticism that Hillerød Municipality's processing of personal data has not been conducted in accordance with the rules in Article 5, paragraph 2, of the General Data Protection Regulation, cf. paragraph 1, letter f, and Article 24, paragraph 1, cf. Article 32, paragraph 1.

Furthermore, the Data Protection Agency finds grounds to express serious criticism that Hillerød Municipality's processing of personal data has not been conducted in accordance with Article 35, paragraph 1, of the Regulation.

In light of this, the Data Protection Agency finds grounds to issue Hillerød Municipality an order to conduct a data protection impact assessment regarding the municipality's processing of personal data in AULA in accordance with Article 35 of the General Data Protection Regulation. The order is issued

pursuant to Article 58, paragraph 2, letter d, of the General Data Protection Regulation. The deadline for compliance with the order is March 22, 2024.

****4.4. General Remarks from the Data Protection Agency****

In system landscapes where multiple data controllers use the same systems and perform approximately the same processing of personal data, there can be significant synergy in conducting joint assessments regarding risk factors, potential impact assessments, and mitigating measures. The Data Protection Agency notes that it may be relevant to conduct a joint impact assessment if several data controllers plan to implement a shared IT system or processing platform, for example, within the municipal sector. For multiple data controllers to collaborate on preparing a joint impact assessment, it is a prerequisite that they are dealing with the same type of system, the same processing activity of the same personal data, and that the processing activities involve similar high risks.

It is not crucial that there is complete identity between the systems and processing activities, but that the system, data, and particularly the processing activities do not deviate significantly from one another. Otherwise, a supplement to the joint impact assessment must necessarily be prepared. Thus, it is the Data Protection Agency's opinion that it would be sufficient for several municipalities to prepare one impact assessment regarding data protection for the processing of personal data in the same system, provided by the same supplier, if the same processing activities are performed in the system, the same types of personal data are processed, and the processing activities involve the same high risks.

It is the responsibility of the data controllers to assess whether a joint impact assessment can be conducted for the processing activities in the systems. The data controllers involved in a joint impact assessment are each responsible for conducting the impact assessment.

The Data Protection Agency believes that in relation to the municipalities' processing of personal data in AULA, the municipalities are using the same type of system for the same processing activities of the same types of personal data, and that the municipalities' processing activities involve similar high risks. Furthermore, the system is provided by the same supplier. The municipalities thus have the opportunity to prepare a joint impact assessment regarding data protection for their processing of personal data in AULA.

In associations and bodies that represent categories of data controllers, it can also be beneficial to develop a code of conduct in accordance with Article 40 of the General Data Protection Regulation with the aim of specifying the application of the General Data Protection Regulation.

A code of conduct can provide correct and practical guidance on how to organize oneself in connection with one or more processing activities to comply with data protection rules. This could, for example, involve establishing procedures that must be followed for a specific processing activity. A code of conduct would therefore be a useful tool to assist in complying with data protection rules for the authorities that have subscribed to the code.

This facilitates compliance with the rules but does not relieve the individual data controller of the obligations and tasks that rest with them as data controllers. This is particularly significant in situations where the data controller chooses to deviate from the assumptions in the common concepts and processing, for example, by using a system for other purposes.

In light of this, the Data Protection Agency encourages consideration across municipalities and possibly in collaboration with KL and KOMBIT to develop a code of conduct in accordance with Article 40 of the General Data Protection Regulation regarding the municipalities' processing of personal data in AULA. This may also be relevant to consider in relation to other processing activities in the municipalities, where the municipalities use the same system to process the same types of personal data for the same purposes.

[1] Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons in relation to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation).

[2] Act No. 502 of May 23, 2018, on supplementary provisions to the regulation on the protection of natural persons in relation to the processing of personal data.

personal data and the free exchange of such information (Data Protection Act).

[3] KL has described the User Portal Initiative on their website: <https://www.kl.dk/kommunale-opgaver/boern-og-unge/digitalisering-paa-boerne-og-ungeomraadet/brugerportalsinitiativet/>

[4] KOMBIT provides information about AULA on the website <https://aulainfo.dk/om-aula/>

[5] It appears from the material regarding the User Portal Initiative, which is available on KL's website: <https://www.kl.dk/media/11560/illustration-af-aftaler-om-databehandling-i-og-omkring-bpi.pdf>

[6] Guidelines for the impact assessment regarding data protection (DPIA) and determining whether the processing "likely involves a high risk" in accordance with Regulation (EU) 2016/679, WP248 rev. 01, adopted on April 4, 2017, as last revised and adopted on October 4, 2017.

[7] Reference is made to the Danish Data Protection Agency's guidance on impact assessments from March 2018.